

NEOLABS

SECURITY LABS | GREY-BOX PENTEST

Week 1 Launch Pack — Operation Night Watch

Weekly Learning Pack | Learn + Connect + Operate

Programme: NeoLabs x Renaissance Innovation Labs Cybersecurity Internship

Week 01

Version: 1.0

Classification: Student Training Material

Authorised synthetic training use only.

Your objective

Create a safe, reproducible map of the **authorised VCC application and its normal HTTP behaviour**. Week 1 is a baseline and mapping exercise, not a vulnerability hunt.

Start in this order

- 1 Clone this Grey-Box Pentest toolkit repository.
- 2 In the repository folder install the NeoLabs CLI:

```
python -m pip install -e .
```

- 1 Set the NeoLabs lab gateway URL supplied in your onboarding message.
- 2 Authenticate with your assigned pod and private Access Code:

```
neolabs login
neolabs status
neolabs pod info
neolabs scope
```

- 1 Retrieve only the server-authorised target information:

```
neolabs targets
```

Do not substitute another IP, hostname, pod or CIDR. If the CLI says the live target is not published, stop and wait for the approved live window rather than scanning anything else.

Read before touching the target

- RULES_OF_ENGAGEMENT.md
- docs/01-professional-foundations/README.md
- docs/02-http-browser-foundations/README.md
- docs/03-burp-suite/README.md
- docs/04-application-mapping/README.md
- docs/tool-setup/burp-community.md
- worksheets/application-mapping-workbook.md

Safe Week 1 workflow

- 1 Confirm the exact server-issued hostname/IP, port and scope.
- 2 Configure Burp Suite Community so only the assigned target is in scope.
- 3 Use the repository's approved low-impact Nmap wrapper/profile only against the exact assigned target.
- 4 Browse the normal learner workflow through Burp Proxy.
- 5 Record request methods, paths, status codes, cookies/session indicators, JSON/API responses and important object identifiers.
- 6 Replay two **normal, non-state-changing** requests in Burp Repeater and explain what each does.

- 7 Note controls you can observe without bypassing them: authentication requirements, redirects, validation, authorization boundaries and security headers.
- 8 Produce a service/request map for later comparison.

Week 1 tasks

- Record student-facing services exposed by the approved target.
- Complete the Application Mapping Workbook.
- Capture at least five normal requests from different parts of the learner workflow.
- Document two safe Repeater observations.
- Record visible security controls without attempting bypass.
- Build a concise attack-surface/service map.

Deliverables

- `service-and-request-map.md`
- completed Application Mapping Workbook
- `testing-journal.md`
- `evidence-register.md`
- redacted screenshots/HTTP evidence where useful

Evidence standard

Every observation should include the target, time, method/tool, result and enough evidence for another tester to reproduce it. Redact Access Codes, session tokens and personal information.

Prohibited in Week 1

- broad scanning
- brute force or credential spraying
- automated exploitation
- destructive/state-changing tests
- scanning any IP/CIDR not returned by `neolabs targets`
- attempting to cross pod boundaries
- denial-of-service or high-rate traffic

Stop conditions

Stop immediately and contact a mentor if a request reaches an unassigned host/pod, reveals real data or credentials, changes unexpected state, affects availability or exposes infrastructure outside the student boundary.

Before submission

- ☐ `neolabs status` shows the correct pod and PENTEST track.
- ☐ `neolabs targets` matches the scope you actually tested.
- ☐ Burp contains only the authorised target in scope.
- ☐ Nmap use was limited to the approved low-impact profile.
- ☐ Five normal requests are documented.
- ☐ No destructive/exploit testing was performed.
- ☐ Evidence is reproducible and redacted.